

智能合約安全檢測報告

檢測工具: Slither
檢測日期: 2026-07-07T13:25:31.149398

1. 摘要結論 (Executive Summary)

本案資安等級: D

偵測到 3 項高風險 (High) 問題尚未排除 (分類非 A) , 需修復並重新掃描後才可交付。

掃描共發現 19 項 (忽略前) , 經過濾與人工分類後剩餘 19 項未忽略。完整分類明細與判定依據見「完整分類明細」章節與附件。

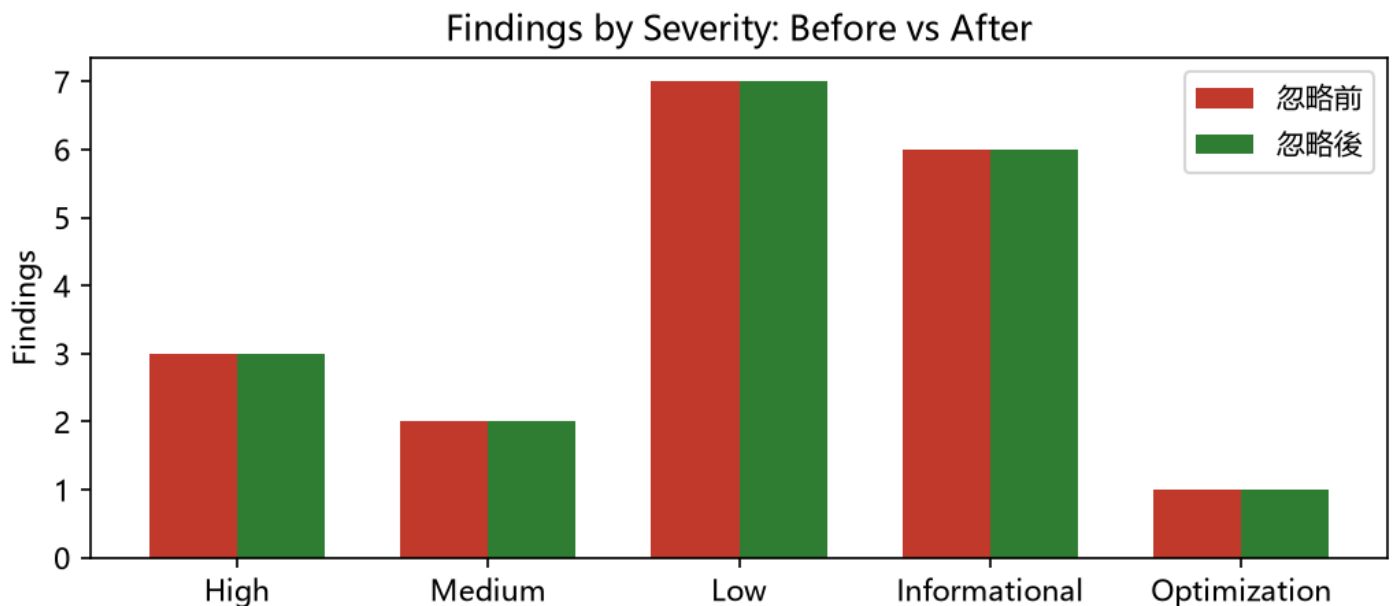
2. 掃描環境資訊

項目	內容
掃描時間	2026-07-07T13:25:31.149398
專案路徑	/home/kai/security-scan-kit/test-fixtures/vulnerable-vault
Git commit	b8561a678f3c12326ba0aa8f4512af3c67c599fc
Solidity / solc 版本	0.8.28
Slither 版本	0.11.5
Foundry (forge) 版本	forge Version: 1.3.5-stable

3. 摘要統計

嚴重程度	忽略前	忽略後	差異
High	3	3	+0
Medium	2	2	+0
Low	7	7	+0
Informational	6	6	+0
Optimization	1	1	+0
總計	19	19	+0

4. 忽略前後對照圖表



5. 完整分類明細

A. 可直接忽略 (False Positive)

#11 `reentrancy-events` [Low] — src/VulnerableVault.sol:[60, 68]

- 原始描述: Reentrancy in safeWithdraw() (event-ordering variant)
- Dev Note: 已確認為誤報: safeWithdraw() 採用正確的 checks-effects-interactions 順序 (balances 在外部呼叫前歸零), reentrancy-events 只檢查事件在外部呼叫之後才 emit, 不代表狀態層級可被重入利用。此為本次測試刻意設計的『安全對照組』函式, 用來驗證工具是否會誤判安全程式碼——結果: 沒有被 reentrancy-eth/reentrancy-benign 誤判, 僅這個最低權重的事件排序 detector 命中, 判定為誤報。

#13 `low-level-calls` [Informational] — src/VulnerableVault.sol:[48, 56]

- 原始描述: Low level call in withdraw()
- Dev Note: 純資訊性提示 (單純標註有低階呼叫), 不構成獨立風險判斷, 實際風險已由 #2 追蹤。

#14 `low-level-calls` [Informational] — src/VulnerableVault.sol:[90, 100]

- 原始描述: Low level call in pickWinner()
- Dev Note: 同上, 純資訊性提示, 實際風險已由 #1 追蹤。

#15 `low-level-calls` [Informational] — src/VulnerableVault.sol:[117, 121]

- 原始描述: Low level call in batchPay()
- Dev Note: 同上, 純資訊性提示, 實際風險已由 #5/#8 追蹤。

#16 `low-level-calls` [Informational] — src/VulnerableVault.sol:[60, 68]

- 原始描述: Low level call in safeWithdraw()
- Dev Note: 同上, 純資訊性提示; safeWithdraw() 本身已確認安全 (見 #11) 。

#17 `naming-convention` [Informational] — src/VulnerableVault.sol:[79]

- 原始描述: Parameter `_paused` is not in mixedCase
- Dev Note: 純命名風格建議, 非安全問題。

#18 `reentrancy-unlimited-gas` [Informational] — src/VulnerableVault.sol:[72, 76]

- 原始描述: emergencyWithdraw() uses transfer() with a fixed 2300 gas stipend
- Dev Note: 純資訊性提示, onlyOwner 才能呼叫, 非本次刻意植入的漏洞項目。

#19 `immutable-states` [Optimization] — src/VulnerableVault.sol:[15]

- 原始描述: owner should be immutable
- Dev Note: 純 gas 優化建議, 非安全問題。

B. 已知風險但可接受 (Accepted Risk)

#6 `events-maths` [Low] — src/VulnerableVault.sol:[110, 114]

- 原始描述: topUpRewardPool(uint256) changes rewardPool without emitting an event
- Dev Note: 只影響鏈下可觀測性, 不影響資金安全; 僅 onlyOwner 可呼叫, 屬已知可接受風險, 非本次測試刻意植入的漏洞項目。

C. 待人工確認

#1 `weak-prng` [High] — src/VulnerableVault.sol:[90, 100]

- 原始描述: pickWinner() uses block.timestamp/block.prevrandao as a source of randomness
- Dev Note: 真實漏洞 (見 VULNERABILITY_CATALOG.md V5) : 得獎者可被驗證者/礦工操縱, 需修復, 不可忽略。

#2 `reentrancy-eth` [High] — src/VulnerableVault.sol:[48, 56]

- 原始描述: withdraw() sends ETH via external call before zeroing balances[msg.sender]
- Dev Note: 真實漏洞 (見 VULNERABILITY_CATALOG.md V1) : 經典重入攻擊, 可被惡意合約清空金庫, 需修復, 不可忽略。

#3 `suicidal` [High] — src/VulnerableVault.sol:[85, 87]

- 原始描述: shutdown() calls selfdestruct with no access control

- Dev Note: 真實漏洞 (見 VULNERABILITY_CATALOG.md V2) : 任何人皆可自毀合約, 需修復, 不可忽略。

#4 `tx-origin` [Medium] — src/VulnerableVault.sol:[79, 82]

- 原始描述: adminSetPaused(bool) uses tx.origin for authorization

- Dev Note: 真實漏洞 (見 VULNERABILITY_CATALOG.md V4) : 可被釣魚合約繞過權限檢查, 需修復, 不可忽略。

#5 `unchecked-lowlevel` [Medium] — src/VulnerableVault.sol:[117, 121]

- 原始描述: batchPay() ignores the return value of the low-level call in the loop

- Dev Note: 真實漏洞 (見 VULNERABILITY_CATALOG.md V7) : 轉帳失敗會被靜默吞掉, 帳務與實際資金不一致, 需修復, 不可忽略。

#7 `missing-zero-check` [Low] — src/VulnerableVault.sol:[72]

- 原始描述: emergencyWithdraw(address,uint256).to lacks a zero-address check

- Dev Note: 涉及資金流向 (轉帳目標地址), 依規則歸類 C: 雖非本次刻意植入的漏洞編號, 但屬真實可改進項目, 需人工確認是否修復。

#8 `calls-loop` [Low] — src/VulnerableVault.sol:[117, 121]

- 原始描述: batchPay() makes external calls inside a loop

- Dev Note: 與 #5 同一根因 (見 VULNERABILITY_CATALOG.md V7) , 同一批修復。

#9 `reentrancy-benign` [Low] — src/VulnerableVault.sol:[48, 56]

- 原始描述: Reentrancy in withdraw() (benign variant)

- Dev Note: 與 #2 同一根因 (V1 的重複偵測) , 一併修復即可解決。

#10 `reentrancy-events` [Low] — src/VulnerableVault.sol:[90, 100]

- 原始描述: Reentrancy in pickWinner() (event-ordering variant)

- Dev Note: pickWinner() 已因 #1 (weak-prng) 被判定為真實漏洞函式, 此處事件順序問題一併留待修復時處理。

#12 `reentrancy-events` [Low] — src/VulnerableVault.sol:[48, 56]

- 原始描述: Reentrancy in withdraw() (event-ordering variant)

- Dev Note: 與 #2 同一根因 (V1 的重複偵測) 。

6. 附錄: C 類待人工確認清單

#	Check	Impact	位置	説明
1	weak-prng	High	src/VulnerableVault.sol:[90,100]	pickWinner() uses block.timestamp as a random number.
2	reentrancy-eth	High	src/VulnerableVault.sol:[48,56]	withdraw() sends ETH via external calls.
3	suicidal	High	src/VulnerableVault.sol:[85,87]	shutdown() calls selfdestruct with the current contract address.
4	tx-origin	Medium	src/VulnerableVault.sol:[73,82]	SetPaused(bool) uses tx.origin to check if the caller is the owner.
5	unchecked-lowlevel	Medium	src/VulnerableVault.sol:[117,124]	handlePay() ignores the return value of lowlevel calls.
7	missing-zero-check	Low	src/VulnerableVault.sol:[72]	emergencyWithdraw(address,uint256) does not check if the amount is zero.
8	calls-loop	Low	src/VulnerableVault.sol:[117,124]	handlePay() makes external calls to payable addresses.
9	reentrancy-benign	Low	src/VulnerableVault.sol:[48,56]	reentrancy in withdraw() (benign because it only sends ETH).
10	reentrancy-events	Low	src/VulnerableVault.sol:[90,100]	reentrancy in pickWinner() (even though it only emits an event).
12	reentrancy-events	Low	src/VulnerableVault.sol:[48,56]	reentrancy in withdraw() (even though it only emits an event).